

Cybersecurity Daily Newsletter

Vol. 005 | 2026-09-18 09:00 WIB

Top 5 Highlights

- AI coding agents' 0-click RCE flaw could hand attackers keys to the kingdom
- New RatHat Android malware uses AI to automate device control
- CISA Ditches Weekly Vulnerability Roundups for Risk-Based Focus
- Cisco patches max-severity ISE flaw, the second critical zero-day this week
- AI hates CAPTCHAs - PSW #944

Threat Intelligence (10)

01. New RatHat Android malware uses AI to automate device control

A new Android malware called RatHat has been discovered, targeting users with an AI-powered subsystem that helps operators remotely navigate compromised devices. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/new-rathat-android-malware-uses-ai-to-automate-device-control/>

02. AI hates CAPTCHAs - PSW #944

AI hates CAPTCHAs - PSW #944

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/podcast-segment/15242-ai-hates-captchas-psw-944>

03. China's FamousSparrow APT Spies on US Politics in Latin America

Amid the US and China's fight for eco-colonial influence in Latin America, a stealthy backdoor has taken flight.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.darkreading.com/cyberattacks-data-breaches/china-famousparrow-spies-latin-america>

04. China's Salt Typhoon backdoors Latin American orgs with new snooping malware

Beware the SparroWocky, my son! The backdoor that bites...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/09/17/chinas-salt-typhoon-backdoors-latin-american-orgs-with-new-snooping-malware/5297286>

05. Brevo supply-chain attack injected ClickFix scripts on customer sites

Brevo confirmed that attackers stole a Cloudflare API key and used it to inject malicious ClickFix scripts into its websites and JavaScript files embedded on customer sites to

distribute malware. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/brevo-supply-chain-attack-injected-clickfix-scripts-on-customer-sites/>

06. LausivLoader analysis, or how to pass data between malware stages, (Thu, Sep 17th)

At the end of August, a malspam message was caught in the quarantine of a mail gateway operated by one of my customers. The message was not especially remarkable â€” it asked the recipient to review some attached requirements and provide a price quotation for a fiber optic system and appeared to impersonate an employee of a legitimate company.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33348>

07. FamousSparrow Swaps SparrowDoor For New SparroWocky Backdoor ESET said FamousSparrow has replaced SparrowDoor with SparroWocky

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/famoussparrow-sparrowocky-latin/>

08. A fake ChatGPT billing email is after your OpenAI password

A fake ChatGPT billing email is steering users to a copy of the OpenAI login page that keeps whatever username and password they type. Josh Varden of Cofense's Phishing Defense Center traced the email's payment button through a Google redirect to the attacker's page. The lure targets ChatGPT users on work and personal accounts alike, and it copies the kind...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.helpnetsecurity.com/2026/09/17/chatgpt-phishing-email-openai-password/>

09. The Odyssey and trojans again: MovieReaper attacks users in multiple countries via compromised torrents

Kaspersky experts have discovered a new MovieReaper campaign. The multi-stage Trojan spreads through movie torrents, such as "The Odyssey," and uses the Solana blockchain to hide its C2 infrastructure.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://securelist.com/moviereaper-malware-torrent-odyssey-solana/121344/>

10. New Chinese-Made 'RatHat' Android Malware Leverages AI to Steal Financial Data

Researchers at Zimperium have uncovered a new Android malware strain, dubbed RatHat, with spyware and backdoor capabilities

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/rathat-android-malware-ai-steal/>

Latest Vulnerabilities (10)

01. AI coding agents' 0-click RCE flaw could hand attackers keys to the kingdom

Plugin4Shell attack affects all the major coding agents, researchers say

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.theregister.com/security/2026/09/17/ai-coding-agents-0-click-rce-flaw-could-hand-attackers-keys-to-the-kingdom/5297335>

02. CISA Ditches Weekly Vulnerability Roundups for Risk-Based Focus

The move is consistent with the agency's advice on the need for organizations to prioritize the vulnerabilities that actually matter.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/cyber-risk/cisa-ditches-weekly-vuln-roundups-risk-based-focus>

03. Cisco patches max-severity ISE flaw, the second critical zero-day this week

Cisco released patches for an actively exploited authentication bypass vulnerability in its Cisco Identity Services Engine (ISE) platform, which is used for enterprise network access

control and policy enforcement. This is the second zero-day flaw Cisco has been forced to release emergency patches for this week, after fixing a critical vulnerability in its...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4223535/cisco-patches-max-severity-ise-flaw-the-second-critical-zero-day-this-week.html>

04. Cisco patches 10.0 ISE bug exploited in the wild

Actively exploited Cisco ISE flaw could give attackers a path to expand network access.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/news/cisco-patches-10-0-ise-bug-exploited-in-the-wild>

05. The Autonomous Engine Behind Remediation, and What Finally Makes It Safe

Executive Summary Vulnerability exploitation now happens at a speed that manual, ticket-based remediation can't match. Qualys's Enterprise TruRisk Management Platform closes that gap with autonomous remediation: exposures are prioritized by threat, business, and environmental context, then validated by TruConfirm and Agent Val before any resource is committed...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://blog.qualys.com/product-tech/2026/09/17/the-autonomous-engine-behind-remediation-and-what-finally-makes-it-safe>

06. OpenAI admits six new misalignment incidents under new reporting framework

OpenAI has published six new reports detailing AI model misalignment, including instances of hidden instructions, unauthorized communication, and attempts to locate exposed API keys, adding to the evidence that its AI systems bypassed controls during testing. The reports, based on internal evaluations, describe models taking actions beyond defined constraints...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4223458/openai-admits-six-new-misalignment-incidents-under-new-reporting-framework.html>

07. VU#280377: Dokploy is vulnerable to OS command injection

Overview Dokploy versions 0.29.8 and 0.29.11, as well as commit 24b02f5 on the canary branch, are vulnerable to OS command injection during the backup creation and restoration processes. The vulnerability stems from unsanitized shell command construction that can allow an attacker to escalate privileges and lead to full compromise of the target device. Desc...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/280377>

08. CISA Retires Weekly Vulnerability Bulletin in Risk-Based Pivot

The decision follows BOD 26-04, which directs federal organizations to prioritize vulnerabilities based on real-world risk. The post CISA Retires Weekly Vulnerability Bulletin in Risk-Based Pivot appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.securityweek.com/cisa-retires-weekly-vulnerability-bulletin-in-risk-based-pivot/>

09. Flaws in The Events Calendar WordPress plugin enable unauthenticated RCE

Both flaws can be exploited by leaving an anonymous comment on an event page.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/news/flaws-in-the-events-calendar-wordpress-plugin-enable-unauthenticated-rce>

10. Iranian strikes on AWS facilities left customer data beyond recovery in Bahrain, UAE

Six months after Iranian drone strikes tore through its Middle East infrastructure, Amazon Web Services (AWS) has acknowledged the permanent loss of customer data in Bahrain and the UAE. In two updates posted September 15, AWS said it can no longer recover customer data and resources stored in its Middle East (Bahrain) region, known as me-south-1, or in one...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.helpnetsecurity.com/2026/09/17/aws-middle-east-outage-permanent-data-loss-bahrain-uae/>

Data Breach & Cybercrime (10)

01. OpenAI Says Its Models Searched GitHub for Leaked API Keys During Training

OpenAI published a framework for disclosing model misalignment alongside six reports describing problematic behavior. The post OpenAI Says Its Models Searched GitHub for Leaked API Keys During Training appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/openai-says-its-models-hunted-github-for-leaked-api-keys-during-training/>

02. Security spending is growing - except for the typical CISO

Security budgets may be growing on paper, but for a majority of CISOs, the money isn't moving in quite the same direction. The budgets grew by 5% on average in 2026, up from 4% last year. But that average hides a much weaker picture: median budget growth remained at 0%. And while 64% of CISOs asked for an increase this cycle, only 45% received one, meaning...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.csoonline.com/article/4223455/security-spending-is-growing-except-for-the-typical-ciso.html>

03. London property manager breach may have exposed bank details and lockbox codes

City Relay says intruders accessed its Metabase Cloud instance twice and extracted customer data

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/09/17/london-property-manager-breach-may-have-exposed-bank-details-and-lockbox-codes/5297232>

04. Revolut phishing texts appear days after data breach

Revolut customers received phishing texts only days after the digital bank acknowledged disclosing customer data to a government impostor.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/09/revolut-phishing-texts-appear-days-after-data-breach>

05. Revolut Data Breach: 5 Months, 680 High-Profile Accounts, \$3M Ransom

Revolut allegedly fed customer information to hackers impersonating an Italian government agency for five months. The post Revolut Data Breach: 5 Months, 680 High-Profile Accounts, \$3M Ransom appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.securityweek.com/revolut-data-breach-5-months-680-high-profile-accounts-3m-ransom/>

06. Druva expands identity resilience with ransomware detection

Druva has announced new capabilities for Druva Identity Resilience alongside the launch of Ransomware Detection, a new feature fueled by a proprietary AI threat pipeline. Powered by Dru MetaGraph, the new offerings use behavioral intelligence and built-in validation to turn suspicious behavior into actionable evidence, definitively confirm impact, and accel...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.helpnetsecurity.com/2026/09/17/druva-identity-resilience-ransomware-detection/>

07. Scammers leave AI fingerprints all over fake antivirus renewal page

AI appears to be helping scammers with little web development skill build convincing fake antivirus-renewal pages, Malwarebytes found. The researchers came across a scam page impersonating Avast, aimed at users in Belgium, that was more polished than most sites of its kind. The page told visitors their Avast Premium Security subscription had renewed for €12...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/17/ai-antivirus-renewal-scam-fake-pages/>

08. [+24h Old] Spain reports first data breach involving autonomous AI agent

Spain's data protection authority (AEPD) has reported its first data breach blamed on an AI agent acting on its own, after the system reportedly logged into a company's network, found a way to alter personal records, and pulled invoice data. "Before drawing any conclusions, it should be noted that the available information comes from the notification submit...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/17/spain-ai-agent-data-breach/>

09. [+24h Old] 16 governance tools for securing your AI fleet

Every DevOps team member knows that dealing with an AI is like being a circus lion tamer. The boss and the audience are happy when the lions sit on the pedestal and roar on cue, but there's always the danger that they'll go rogue and bring the whole show to a quick and disastrous end. The reality is that running LLMs in production means being ready to handl...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.csoonline.com/article/4223011/16-governance-tools-for-securing-your-ai-fleet.html>

10. [+24h Old] AI Agent Carries Out Multi-Stage Data Theft Attack

Spanish data protection agency AEPD reveals the country's first AI-powered data breach

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/ai-agent-carries-out-multistage/>